# Master Development Prompt (Revised): Tanzanian Regional Referral Hospital HMS

Phased, security-hardened rewrite with a full hospital-grade UI specification

## How to use this prompt

Paste **Part A (Context), Part B (Security), Part C (Clinical Safety) and Part D (UI Design System)** at the start of every session, then paste **one phase from Part E** at a time. Do not ask for the whole system in one request. After each phase, review the output against that phase's acceptance criteria before starting the next.

---

## Part A: Context and constraints

**Role.** You are a senior Laravel architect and healthcare-systems engineer. Build a Hospital Management System (HMS) for a Tanzanian Regional Referral Hospital.

**Pinned stack.**

- PHP 8.3, Laravel 11 (or current LTS if newer), MySQL 8.0, Redis 7, Nginx + PHP-FPM, Linux (Ubuntu LTS).
- Core is PHP/Laravel and MySQL. The following named supporting services are permitted and nothing else without justification: Redis (cache, sessions, queues), Nginx, Orthanc (DICOM/PACS), an HL7/ASTM interface engine or library for analysers, and a CDN for static assets only.
- Front end: server-rendered Blade templates with plain CSS (design tokens in Part D) and a minimal amount of vanilla JavaScript or Alpine.js. No SPA framework, no external CDN fonts or scripts at runtime.

**Hosting and data residency.** Assume an on-premises or in-country server environment with intermittent power and connectivity. All personal health data must remain in Tanzania.

**Facility model.** Multi-facility ready from day one (facility_id on all tenant-scoped tables), initially deployed for one regional referral hospital.

**Languages.** Swahili and English, complete coverage, switchable per user. All strings in language files, none hardcoded.

**Legal and standards.**

- Tanzania Personal Data Protection Act (2022): consent capture, purpose limitation, retention schedule, data-subject access and correction, breach notification workflow.
- National standards: GoT-HoMIS, DHIS2 (MTUHA aggregates), HL7 FHIR for patient exchange, Health Facility Registry (HFR), NIDA (optional), NHIF, MSD and TMDA where relevant.
- Diagnosis coding: **ICD-10** is the system of record (insurers require it). ICD-11 may be stored as an optional secondary mapping.
- Integration positioning: the HMS **syncs with** national systems (GoT-HoMIS, DHIS2, HIE/OpenHIM mediator where available). It does not replace them. All external endpoints, payload mappings and credentials are configuration, never hardcoded, and every integration ships with a sandbox/mock adapter.

**Working rules for the assistant.**

- State assumptions explicitly. Do not invent endpoints, field names or tariffs; where an external specification must be confirmed, create a config entry marked `VERIFY_WITH_PROVIDER` and a mock.
- No placeholder code, no "implement later" stubs in delivered files.
- Deliver in this order for every phase: migrations, models, policies, services, form requests, controllers, Blade views, seeders, tests, OpenAPI fragment, short documentation.

---

# Part B: Security and privacy requirements (non-negotiable)

**Access control**

- RBAC with granular permissions, plus **object-level checks** in Laravel Policies: facility, department and care-relationship (a clinician sees patients assigned to or encountered by their unit unless break-glass is used).
- **Break-glass access**: requires a reason, time-limited, notifies the privacy officer, and appears in a review queue.
- MFA (TOTP) mandatory for administrators and prescribers; configurable for others. Session idle timeout 15 minutes (configurable), absolute timeout 12 hours, concurrent-session policy.
- Password policy: minimum length 12, breach-list check, lockout with backoff, forced reset on first login.

### Credentials and keys

- Two distinct stores:
  1. **Outbound secrets** (NHIF username/password, MoH `X-Service-Token`, DHIS2 credentials): encrypted at rest with Laravel encryption (key from environment, rotatable), editable only by ICT administrators, never displayed after saving, never written to logs.
  2. **Inbound API keys** issued to other systems: generated once, shown once, stored **hashed only**, with scopes, expiry, per-key rate limits, last-used time and usage log.
- Redact `Authorization`, `X-Service-Token`, passwords and national IDs from all logs and error reports.

### Data protection

- HTTPS only with HSTS. Redis requires authentication, binds to a private interface and uses TLS; treat Redis as a store of patient data.
- Page/fragment caching is restricted to genuinely public pages. Never cache patient-identifiable pages or reports.
- Encrypt sensitive columns (national ID, phone, next of kin) at the application layer; encrypted backups, off-site copy, **quarterly restore tests**, targets RPO 15 minutes and RTO 4 hours (configurable).

### Application hardening

- CSRF protection, output escaping everywhere (clinical free text is untrusted), parameterised queries only, `$fillable` allow-lists (no mass-assignment), strict file-upload validation (type, size, content sniffing, storage outside web root, malware scan hook).
- Security headers (CSP without inline scripts, X-Frame-Options, Referrer-Policy, Permissions-Policy).
- Dependency scanning in CI (composer audit), static analysis (Larastan level 8), and a documented penetration-test checklist to complete before go-live.

### Audit

- Append-only audit log covering **reads and writes** of patient records, logins, permission changes, key operations, exports, prints and break-glass use. Record user, role, facility, patient, action, timestamp, IP and device.
- Clinical records are **versioned and never hard-deleted**. Corrections create a new version with a reason; cancelled items are voided with a reason.

- Audit tables are write-only for the application database user and protected from modification.

---

## Part C: Clinical safety requirements

- **Read-your-writes consistency:** clinical reads (allergies, active medications, orders, results) must go to the primary database or verify replica lag below a set threshold. Replicas may serve reports and non-critical lists only.
- **Cache invalidation:** drug formulary, tariffs and rosters are cached in Redis with explicit invalidation on change and a maximum TTL. Allergy, medication and result data are never served from a stale cache.
- **Decision support is deterministic and rule-based:** drug-drug interaction, allergy conflict, duplicate therapy, renal/paediatric/pregnancy dose-range and maximum-dose checks. Name the source dataset in configuration (for example a licensed interaction database or the Tanzania Standard Treatment Guidelines and National Essential Medicines List). Every alert shows its rule, severity and source; overrides require a coded reason and are audited.
- **Patient identity:** unique MRN generated concurrency-safely (database sequence or locked counter), master patient index with probabilistic duplicate detection, **merge and unmerge** workflows with full audit, optional NIDA verification.
- **Positive patient identification:** two-identifier confirmation and barcode scanning at specimen collection, dispensing and medication administration.
- **Claims safety:** NHIF claim submission uses **idempotency keys**, a retry policy with backoff, a dead-letter queue, and visible rejection handling with reason codes. A claim can never be submitted twice for the same folio.
- **Downtime operation:** local-first read access to a downtime summary (current inpatients, allergies, active medications), printable downtime forms, and a **paper-to-system reconciliation** screen that records who back-entered what and when.

---

# Part D: UI design system (hospital-grade, no decoration, no AI features)

## D1. Design principles

1. **Clinical clarity over appearance.** The interface exists to prevent errors and save time at the point of care.
2. **Plain, neutral, predictable.** The same pattern for the same task everywhere.
3. **Information density with legibility.** Clinicians need to see more, not less, without squinting.
4. **Safety-critical information is never hidden** (allergies, alerts, patient identity, location).
5. **Works on poor infrastructure:** low bandwidth, older browsers, shared workstations, intermittent power.

## D2. Strict prohibitions

The following must **not appear anywhere**: UI, notifications, emails, SMS templates, PDFs, seed data, error messages, documentation or code comments.

- **No emoji or emoticons** of any kind, and no decorative Unicode symbols used as icons.
- **No AI-like features or styling:** no chatbot or assistant panel, no "Ask AI" or "Suggest" buttons, no sparkle or magic-wand icons, no auto-generated summaries or narrative text, no predictive or "smart" autofill of clinical free text, no generated recommendations presented as advice, no "insights" widgets.
- **No conversational or personalised microcopy:** no greetings such as "Good morning, Doctor", no motivational or celebratory messages, no mascots, no first-person system voice ("I found…"). Use neutral, imperative, factual text.
- **No decorative effects:** no gradients, glassmorphism, glow, parallax, animated illustrations, confetti, skeleton shimmer, or auto-playing motion. Transitions limited to instant state changes; honour `prefers-reduced-motion`.
- **No stock imagery, illustration or marketing-style hero sections.** Login page shows facility name, logo, and the form.
- Rule-based clinical alerts are permitted and are presented as plain alerts (see D8), never described as intelligent or AI.

## D3. Visual foundation (design tokens)

Define as CSS custom properties; light theme only (a high-contrast variant is optional).

| Token | Value | Use |
|---|---|---|
| `--bg-page` | `#F4F6F8` | Page background |
| `--bg-surface` | `#FFFFFF` | Panels, tables, forms |
| `--text-primary` | `#1A202C` | Body text |
| `--text-secondary` | `#4A5568` | Labels, help text |
| `--border` | `#CBD2D9` | Dividers, inputs |
| `--primary` | `#0B5CAD` | Primary actions, links, active nav |
| `--primary-dark` | `#084A8C` | Hover and focus |
| `--critical` | `#B42318` | Critical alerts, errors, allergies |
| `--warning` | `#B54708` | Warnings, abnormal results |
| `--success` | `#067647` | Completed, normal |
| `--info` | `#175CD3` | Informational notices |

- **Colour is never the only signal.** Every status uses a text label (for example "CRITICAL", "Abnormal - High") in addition to colour.
- **Typography:** self-hosted system-safe sans-serif (for example Noto Sans or Source Sans 3, with `system-ui` fallback), 14 px base on desktop, 16 px minimum for form inputs on touch devices, line-height 1.4, tabular numerals for clinical values. Headings are plain weight 600, no decorative fonts.
- **Spacing and shape:** 4 px base unit, corner radius 2 to 4 px, single 1 px borders, at most one subtle shadow level for modal dialogs only.
- **Icons:** a single monochrome line-icon set, used only when functional, always accompanied by a visible text label. No icon-only buttons except universally understood controls (close, print) with accessible names.

## D4. Layout and navigation

- **Top bar (fixed):** facility name, current department/location, user name and role, language toggle (SW / EN), connectivity status ("Online", "Offline - working locally"), session time remaining, and sign out.

- **Left navigation (fixed, 240 px, collapsible):** grouped by directorate, mirroring the departmental structure: Clinical Services, Diagnostics and Therapeutics, Nursing and Midwifery, Administration and Support, Public Health and Reporting, System Administration. Items shown only if the user has permission.
- **Persistent patient banner** (sticky, shown on every screen inside a patient context): full name, MRN, age and sex, date of birth, photo (if captured), allergies (with "No known allergies" stated explicitly when confirmed), active alerts, payer (cash, NHIF, other), current location and encounter type. Never collapsible.
- **Work-queue-first home screens** per role (see D7), not decorative dashboards.
- **Breadcrumbs** on all pages deeper than two levels. Global patient search always available in the top bar (name, MRN, phone, NIDA, NHIF number).

## D5. Core components

- **Data tables:** sticky header, server-side sorting, filtering and pagination, column chooser, keyboard row navigation, selected-row highlight, row actions as text links or buttons, CSV and PDF export where permitted. Empty states show a plain sentence and the available action.
- **Forms:** labels above fields, never placeholder-as-label; required fields marked with the word "Required"; units shown beside numeric inputs; inline validation on blur with specific messages; logical tab order; autosave of drafts for long clinical notes with a visible "Draft saved at HH:MM" indicator. Dates as dd/mm/yyyy, time as 24-hour, timezone Africa/Dar_es_Salaam.
- **Buttons:** one primary action per view (filled `--primary`), secondary actions outlined, destructive actions use `--critical` and always require confirmation. Button text states the action ("Save encounter", "Dispense", "Submit claim").
- **Dialogs:** used only for confirmation and short inputs. Critical confirmations restate the patient name and MRN and the exact action.
- **Alerts and banners:** four types (Critical, Warning, Info, Success), each with a text label, short message and, where relevant, the rule or reference. Critical alerts require acknowledgement and are logged.
- **Status tags:** square-cornered text tags ("Pending", "In progress", "Verified", "Cancelled"), consistent vocabulary across modules.
- **Charts:** only where they serve clinical work (vital signs trends, growth charts, partograph, epidemic curve), drawn with accessible, labelled axes, data table alternative available. No decorative KPI tiles.

- **Print views:** A4 layouts with facility header, patient identifiers and barcode/QR, for prescriptions, lab reports, discharge summaries, wristbands, referral letters and invoices. Print stylesheet strips navigation.

## D6. Content and microcopy

- Neutral, factual, imperative language in both Swahili and English; short sentences; standard clinical terminology and ICD-10 labels.
- Error messages state what happened and what to do ("Weight must be between 0.3 and 300 kg. Re-enter the value."). No apologies, humour or exclamation marks.
- Confirmations are plain ("Encounter saved"), not celebratory.
- Abbreviations limited to an approved list shown in help; avoid ambiguous ones.

## D7. Screen specifications

Build each screen with the components above. For every screen, provide loading, empty, error, no-permission and offline states.

1. **Sign-in:** username, password, MFA code step, facility selection, language toggle, notice on authorised use. No imagery.
2. **Role home (work queue):** OPD doctor (consultation queue, pending results), triage nurse (waiting list with triage category), ward nurse (assigned patients, due medications), laboratory (pending orders, samples awaiting), radiology (worklist), pharmacy (prescriptions awaiting verification and dispensing), cashier (open bills), records (registration, file requests), administrator (users, integration status, queue failures).
3. **Patient search and MPI:** search results table with identifying fields, duplicate warning, merge candidate review, NIDA verification result.
4. **Registration:** demographics, next of kin, payer and NHIF verification, consent capture, MRN issued on save, wristband and card print.
5. **Triage:** vital signs with range flags, triage category (text and colour), chief complaint, queue assignment.
6. **OPD consultation:** single-page encounter with sections History, Examination, Diagnosis (ICD-10 search), Orders, Prescription, Plan. Previous encounters and results in a side panel. Free-text fields are plain text boxes with no generated content.
7. **Orders and results:** lab and radiology order entry, specimen tracking with barcode scan, result entry with reference ranges and abnormal flags, validation step, critical-value acknowledgement.

8. **Pharmacy:** prescription verification screen with interaction/allergy/dose alerts, dispensing with batch and expiry selection, stock levels, MSD requisition.
9. **IPD:** ward bed board (bed status as text and colour), admission, daily notes, nursing care plan, vital signs flowsheet, medication administration record with barcode confirmation, discharge summary, referral.
10. **Maternity and paediatrics:** ANC visit schedule, partograph (graph with alert and action lines), newborn record, immunisation schedule and growth charts.
11. **Theatre:** schedule grid, pre-operative checklist, operation note, anaesthesia record, post-operative orders.
12. **Billing and claims:** itemised bill, payer split, GePG control number and mobile-money status, NHIF claim builder with validation, submission status and rejection reasons.
13. **Procurement, stores and biomedical engineering:** requisitions, purchase orders, GRN, stock ledger, equipment register, maintenance work orders.
14. **Human resources:** staff profiles, duty roster grid, leave, training records.
15. **Reports:** MTUHA/DHIS2 aggregates with data-element mapping view, submission history, disease surveillance notifications.
16. **System administration:** users and roles, permission matrix, audit log viewer with filters, break-glass review queue, outbound credentials, inbound API keys with usage and rate limits, queue and integration health, backup status.
17. **Downtime mode:** persistent banner, read-only summary views, printable forms, reconciliation screen.

## D8. Clinical alert presentation

- Displayed inline at the point of action, never as a floating assistant.
- Format: severity label, one-line statement of the issue, the rule or source, and the available actions ("Change drug", "Override with reason"). No friendly or explanatory chat-style text.
- Override reasons are selected from a coded list and recorded.

## D9. Accessibility and performance

- WCAG 2.2 AA: contrast of at least 4.5:1, full keyboard operation, visible focus outline, semantic HTML and ARIA landmarks, labels programmatically associated, no content that relies on colour alone, 44 px minimum touch targets on tablets.

- Page weight budget under 300 KB per screen, first meaningful content under 2 seconds on a 3G-class connection, no third-party trackers or runtime CDN dependencies for fonts or scripts, graceful behaviour on older browsers used in hospital workstations.

---

# Part E: Delivery phases

For every phase deliver: migrations, models, policies, services, requests, controllers, Blade views per Part D, seeders, tests (feature and unit), OpenAPI fragment, and a short README section. Apply Parts A to D throughout.

## Phase 1: Foundation

**Scope:** project scaffolding, configuration, authentication with MFA, RBAC and object-level policies, break-glass, audit logging, user and facility administration, localisation (Swahili/English), design system (tokens, layout, components), master patient index and MRN, registration, triage, OPD consultation (ICD-10, prescriptions as orders), cash and exemption billing.

**Acceptance criteria:**

- A user without a care relationship cannot open a patient record except via break-glass, verified by automated tests.
- Every read and write of a patient record produces an audit entry.
- MRN generation is collision-free under 50 concurrent registrations in a test.
- All screens in scope pass the prohibitions check in D2 (automated scan for emoji and banned elements) and WCAG automated checks.
- Test coverage of at least 80% on services and policies.

## Phase 2: Diagnostics and pharmacy

**Scope:** laboratory (orders, barcode/QR specimens, result validation, analyser interface via ASTM/HL7 adapter with mock), blood bank basics, radiology orders and reports with Orthanc DICOM/PACS integration, pharmacy (verification, dispensing, batch and expiry inventory, deterministic decision support per Part C).

**Acceptance criteria:**

- Allergy and interaction alerts fire in tests for seeded cases and show rule and source.
- Specimen and dispensing flows enforce two-identifier or barcode confirmation.

- Stock deductions are transactional and cannot go negative.

## Phase 3: Inpatient, maternity and theatre

**Scope:** IPD admissions and bed management, nursing care plans, vital signs, MAR, discharge and referral, obstetrics (ANC, partograph, delivery, postnatal, family planning), paediatrics (immunisation, growth, NICU/PICU), theatre scheduling and records, emergency department, specialised clinics, physiotherapy, nutrition.

**Acceptance criteria:**

- Bed board reflects state changes within 5 seconds for concurrent users.
- MAR requires barcode confirmation and records every omission with a reason.
- Partograph renders alert and action lines correctly against test data.

## Phase 4: Integrations

**Scope:** inbound API key management and outbound credential vault (Part B), NHIF (token, member verification, claim submission, referral) with idempotency and dead-letter handling, DHIS2 aggregate push, HL7 FHIR resources (Patient, Encounter, Observation) for HIE compatibility, HFR synchronisation, optional NIDA verification, GePG control numbers and mobile-money payments. All behind configuration with mock adapters.

**Acceptance criteria:**

- Duplicate submission of the same claim is rejected by test.
- Credentials never appear in logs or in the UI after save.
- Each integration can be switched between mock and live by configuration only.
- Failed jobs are visible to administrators with the reason and a retry control.

## Phase 5: Administration, reporting, hardening and deployment

**Scope:** human resources, procurement, stores, estates and biomedical engineering, MTUHA reports and disease surveillance (eIDSR), community referral feedback, performance work (OPcache, Redis object cache and sessions, queues, read/write splitting for non-clinical reads, MySQL tuning, Nginx and PHP-FPM tuning, load balancing), downtime mode, backups and restore drills, deployment guide, penetration-test checklist, user documentation.

**Acceptance criteria:**

- Load test: 300 concurrent users with 95th-percentile response under 1.5 seconds on core screens, results documented.
- Restore drill completed from backup within the stated RTO.
- Replica lag guard verified: clinical reads never served from a lagging replica.
- Deployment guide reproduces a working environment on a clean Ubuntu server.

---

## Part F: Global definition of done

- All code passes static analysis (Larastan level 8), code style checks, and the full test suite in CI.
- OpenAPI documentation covers every internal and external endpoint and validates against the code.
- No emoji, AI-style features or banned decorative elements exist anywhere in the repository (automated check in CI).
- Security checklist in Part B is signed off item by item, and open risks are listed.
- Every external specification assumption is recorded in an assumptions register with its verification status.